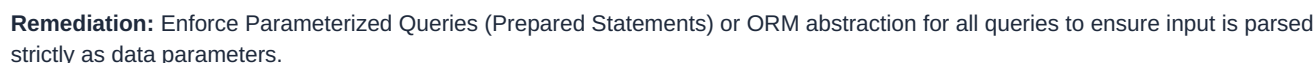


A targeted vulnerability assessment and penetration test was conducted against a local instance of **OWASP Juice Shop** following the **OWASP Top 10** standard. Critical, high, and medium-severity vulnerabilities were identified across authentication, authorization boundaries, client-side input reflection, and server asset configurations.

ID	Vulnerability Title	OWASP Category	Endpoint	CVSS	Severity
SEC-01	SQL Injection (Auth Bypass)	A03:2021 - Injection	POST /rest/user/login	9.8	CRITICAL
SEC-02	Insecure Direct Object Reference (IDOR)	A01:2021 - Broken Access Control	GET /rest/basket/{id}	7.5	HIGH
SEC-03	DOM-based Cross-Site Scripting (XSS)	A03:2021 - Injection	GET /#/search?q=	6.1	MEDIUM
SEC-04	Sensitive Directory Listing Exposure	A05:2021 - Security Misconfiguration	GET /ftp	5.3	MEDIUM

CRITICAL | CVSS 9.8

Proof of Concept (Burp Suite HTTP Request & Response):



HIGH | CVSS 7.5

Description: The API references user cart objects via sequential integer IDs without validating whether the requesting session owns the target basket. Modifying the basket identifier from 1 to 2 exposes unauthorized user cart contents.

[illegible]

CONFIDENTIAL - WEB APPLICATION PENETRATION TESTING REPORT

SEC-03: DOM-based Cross-Site Scripting (DOM XSS) in Search Filter

MEDIUM | CVSS 6.1

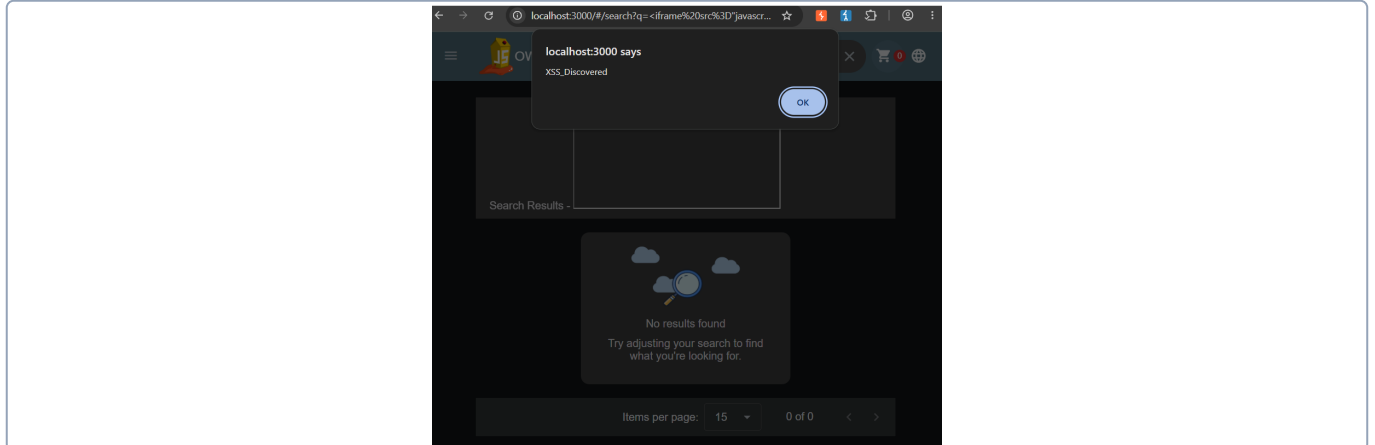
Vulnerability Class: OWASP A03:2021 - Injection (CWE-79) | **Endpoint:** GET /#/search?q=

Description: The search query parameter is directly written to the client-side DOM sink without contextual HTML entity encoding. Injecting an inline iframe payload executes arbitrary client-side JavaScript within the browser context.

Exploit Payload:

```
<iframe src="javascript:alert(`XSS_Discovered`)">
```

Proof of Concept (JavaScript Execution in Client DOM):



Remediation: Enforce strict contextual output encoding (HTML entity escaping) and configure a robust Content Security Policy (CSP) restricting inline script execution.

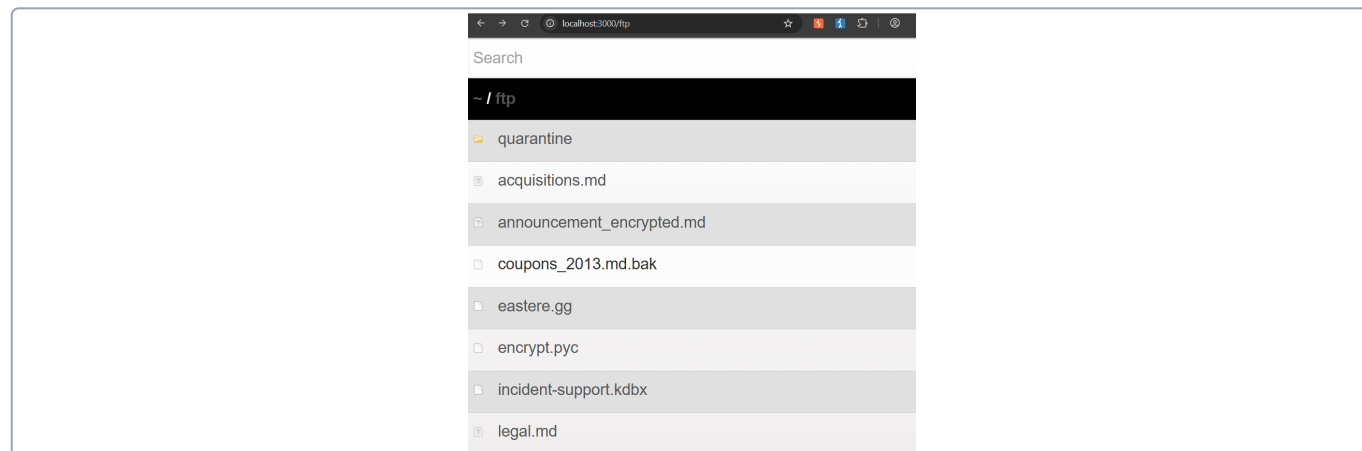
SEC-04: Sensitive Directory Listing & Confidential Asset Exposure

MEDIUM | CVSS 5.3

Vulnerability Class: OWASP A05:2021 - Security Misconfiguration (CWE-548) | **Endpoint:** GET /ftp

Description: The application exposes an open FTP backup directory discovered via /robots.txt. Directory indexing is enabled, permitting unauthenticated visitors to view and download internal backup files, incident support databases (incident-support.kdbx), and confidential acquisition notes (acquisitions.md).

Proof of Concept (Exposed Directory Indexing):



Remediation: Disable web server directory browsing/indexing and restrict public routing to sensitive storage folders using strict access-control filters.

4. ASSESSMENT CONCLUSION

The penetration test identified high-impact risks across authentication, authorization boundaries, client-side input reflection, and asset protection. Remediation requires implementing parameterized statements, strict role-based object authorization, contextual HTML encoding, and disabling directory indexing.